

[doc. web n. 9920814]
Provision of June 22, 2023
Register of provisions
n. 263 of June 22, 2023

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN THE meeting today, attended by
Prof. Pasquale Stanzione, President, Dr.
Agostino Ghiglia and Attorney Guido Scorza, members, and
Dr. Claudio Filippi, Deputy Secretary General;

HAVING REGARD TO Regulation (EU) 2016/679 of the European Parliament
and of the Council, of April 27, 2016 (hereinafter, "Regulation");

HAVING REGARD TO the Code regarding the protection of personal data, containing provisions for
the adaptation of the national legal system to Regulation (EU) 2016/679 (Legislative Decree of June
30, 2003, n. 196, as amended by Legislative Decree of August 10, 2018, n. 101, hereinafter "Code");

HAVING REGARD TO the report submitted by Mr. XX and Mr. XX
against Maviglia Assicurazioni snc of Gherardo Maviglia & c.;

HAVING EXAMINED the documentation on file;

HAVING REGARD TO the observations made by the Deputy Secretary General pursuant to Article 15
of the Guarantor's Regulation n. 1/2000;

REPORTING Attorney Guido Scorza;

PREMISE

1. The initiation of the preliminary investigation following
the report received.

With a report submitted on 12/01/2021, supplemented by a communication on 09/06/2021, Mr.
XX and Mr. XX complained of a violation of the
regulations on the protection of personal data by Maviglia Assicurazioni snc of
Gherardo Maviglia & c. (hereinafter "the Agency"), regarding the persistent activation of
the corporate email accounts, of an individualized type (XX and XX), to which third parties would have
accessed, following the termination of their collaboration with the Agency.

With a note dated 11/03/2022 (prot. n. 14961), the Office
formulated a request for information to the Agency, aimed, in particular, at ascertaining whether
the email accounts assigned to the two former collaborators were still active and whether an automatic
response system had been activated for incoming emails, indicating the deactivation of the
aforementioned accounts.

The Agency, with a note dated 06/04/2022, responded to
the Office's requests, stating that:

- following the termination of the collaboration with the two reporters (which occurred in February
2020), it promptly informed

"IVASS of the termination of the collaboration, also taking care to block their corporate email accounts,
which could therefore no longer be viewed or used by any of the company's employees, except for the
I.T. manager of the same (...) and the person responsible for the reassignment of clients (...);"

- the definitive deactivation of the accounts, however, was ordered on 04/06/2022, that is, within 120
days from the termination of the collaboration, in accordance with a consolidated company practice;

- indeed, this period of time "is necessary to allow the agency to reassign and redistribute the policy
and client portfolio of the terminated worker to other collaborators. This is not, in fact, an automatic and
immediate activity, as the general agent must make various estimates and evaluations, both of the
aforementioned portfolio and of the workload, capabilities, and availability of the other collaborators, to
determine the methods of distribution. This is evidenced by the fact that Maviglia Ass.ni, precisely in
order to make this activity as swift as possible, has appointed an internal person to manage the

reorganization of the portfolios of former collaborators”;

- “Only for this brief interval of time could the corporate email account of the employees, which had been blocked and thus access was inhibited to anyone, still receive emails, which were automatically redirected to the corporate address of the distribution manager, (...) who, however, had no authority to view them independently, having to refer to the I.T. manager for the management of communications from the aforementioned mailboxes”;

- “About a month after the termination of the employment relationships with Mr. XX and Mr. XX, Maviglia Ass.ni had almost completed the procedures for the reassignment of the portfolio, promptly informing clients about the name of their new reference agent”;

- in conclusion, “no control has ever been carried out on the blocked corporate emails, unless this was requested – paradoxically – by the complainants themselves and, in any case, it would have been carried out only if it had not been possible to proceed otherwise, or if circumstances arose (such as complaints from clients or their communications erroneously sent to the blocked addresses or information regarding the expiration date or renewal of insurance guarantees), for which the control of the aforementioned corporate emails would have been necessary to protect the interests of the insured.”

Following a request for further clarification, made on 26/05/2022 (prot. n. 28784), the Agency sent a communication on 16/06/2022, in which it stated that:

- “regarding the current status of the email accounts of the complainants (...) [this] is currently deleted, as it has been ordered.

the cancellation within 120 days from the date of termination of the relationship”;

- “Maviglia s.n.c. is a General Agency that carries out its insurance intermediation activities on behalf of the principal company Generali Italia S.p.A., a listed company subject to auditing and control.

Therefore, the contracts of the reporters XX and XX, as well as the related documentation attached to them, were prepared by Generali Italia itself and delivered, by Maviglia Ass.ni s.n.c., to the reporters”;

- with particular reference to the methods of use of IT resources by its collaborators, “in attachment 7 to the appointment letter [as data processor] titled ‘behavioral rules regarding corporate IT resources,’ the methods by which employees and collaborators are allowed to use the IT resources made available to them for the performance of their assigned duties, including the regulation of the use of corporate email, are clearly specified. This attachment is provided to all employees and collaborators at the beginning of the inter partes relationship” as evidenced by the document signed by one of the reporters;

- regarding the management of corporate email, given that each collaborator has an email address with a corporate domain, in the phase following the termination of the collaboration relationship, “Maviglia implements an automatic block of the email addresses assigned to the former collaborator/employee, for a maximum period of 120 days after which it is definitively deleted, manually by the agency's IT manager.” On this specific aspect, the Agency clarified that:

- “no access or entry is made into the corporate accounts of former employees, as the preparation of the block of incoming and outgoing email flow, immediately implemented by the agency upon termination of the relationship with its collaborators, is carried out without accessing personal mailboxes and, above all, once the aforementioned email block is implemented, it is no longer possible or necessary to access them, as an automatic email message is sent to the sender informing them of the inactivity of the email address”;

- “the content of the email of the agency's employees and collaborators is managed and protected using IT tools provided by the provider Aruba.” From the examination of the documentation attached to the aforementioned notes of response (see in particular attachment 20), it was found, in particular, that:

- “The company provides its employees with the IT resources they need to fulfill their duties” (attachment 7 of the referenced attachment 20);

- “Internet access is allowed only to personnel with specific authorization. (...) Internet access will occur through pathways (Gateways – firewall or proxy) that automatically record and maintain evidence of the connections made and the internet addresses contacted. This recording, called a log, is kept by the company solely for security reasons and the protection of corporate assets”;

- "Activities related to the corporate email system are also archived in specific files that automatically record and maintain evidence of all activities performed, including the destination/source addresses of the messages. This recording is called a log and is kept by the company solely for security reasons and the protection of corporate assets";
- "In the event of termination of the employment relationship (and/or consultancy/collaboration), the content of the email or other IT resources assigned to the terminated employees will remain available to the company and may be used by it exclusively for reasons related to the conduct of business activities";
- "In order to protect itself against illegal or potentially harmful behaviors, (...) the company reserves the right to carry out checks on the use of IT resources by employees. Such checks may also be carried out electronically and may include the verification of logs (...)"

2. The initiation of the procedure for the adoption of corrective measures. The Office, in light of the above, proceeded to notify the Agency of the act initiating the sanctioning procedure, pursuant to Article 166, paragraph 5, of the Code (note prot. no. 58003 of 24/10/2022), for the violation of Article 5, paragraph 1, letters a), c) and e) and Article 6 of the Regulation in relation to:

- automatic redirection of messages in transit on the accounts of the two former collaborators, to another corporate account, for a period of 120 days. This activity resulted in the knowledge of the content of the messages received on the aforementioned accounts by unauthorized third parties and, moreover, it lasted for a period that is excessive and not justified by the declared organizational needs;
- the systematic retention, without time limits, of the logs of the email during the collaboration relationship;

- retention, without defined time limits, of the content of the correspondence that passed through the individualized email accounts, as well as their availability for the purposes of continuity of business activities. The Agency, on 18/11/2022, sent its defensive memos based on Article 18 of the law. n. 689/1981, which reiterated that:

- "once the employment relationship with a collaborator/employee has ended, the corporate email address assigned to them [is] immediately deactivated (by resorting to the blocking procedure provided by the Aruba software used by the agent). Then, after a maximum period of 120 days from the termination of the employment/collaboration relationship, the email accounts are deleted and no type of consultation is possible, not even for those responsible for monitoring such addresses. Furthermore, it is important to note that this automatic redirect message, prepared by the Aruba software (...), is sent to the senders via email, to inform them that the address to which they have forwarded the message is no longer active";
- "emails are redirected to the account of a single person appointed by Maviglia as responsible (...) and only for the strictly necessary period (in this case less than 30 days) for an initial sorting of clients (...). Therefore, as soon as the clients are sorted, the automatic redirect email ceases";
- ultimately, the procedure provides for: "(i) the immediate blocking/deactivation of the corporate email with automatic redirection to the email of a designated person who cannot access the content of the emails, (ii) sending a message to all clients and indicating their new contact person, in a very short time, (iii) identifying a person who has the 'access keys to the email address of former employees' (which is not the same one to which messages are redirected immediately after the termination of the relationship); (iv) after a maximum period of 120 days (which may also be shorter), the definitive deletion of the email box in question occurs."

On 08/02/2023, the hearing of the party took place, during which the observations already made during the investigation were reiterated and it was specified that, at the end of the 120 days provided for the management of the client portfolio, "it is no longer possible to recover any correspondence or documentation also because the Agency does not have its own backup."

3. The outcome of the investigation and the procedure for the adoption of corrective and sanctioning measures.

As a result of the examination of the statements made by the party during the procedure, as well as the documentation acquired, it appears that the Agency, as the data controller, has carried out some processing operations that are not compliant with the regulations on the protection of personal data. In this regard, it is highlighted that, unless the act constitutes a more serious offense, anyone who, in a

proceeding before the Guarantor, falsely declares or certifies news or circumstances or produces false acts or documents is liable under Article 168 of the Code "Falsehood in declarations to the Guarantor and interruption of the execution of the tasks or the exercise of the powers of the Guarantor."

3.1 Violation of Article 5, paragraph 1, letters a) and e) of the Regulation.

It should be noted, preliminarily, that the statements made by the party have often been unclear and sometimes contradictory during the procedure, particularly with regard to the aspect related to the "blocking of email accounts."

In fact, while on one hand it is emphasized that upon termination of the employment relationship, the accounts are blocked with the impossibility of sending and receiving messages, on the other hand, it is also stated that incoming emails are redirected to another account, so much so that access to the content of the messages would only be allowed to the IT Manager, subject to authorization from the owner and the interested party and in the presence of particular needs.

In any case, from the examination of the documentation produced, it emerges that the Agency has kept active, after the interruption of the collaboration relationship, the corporate email accounts, individualized, assigned to the two reporters, for a period of 120 days.

During this period, the emails in transit on the aforementioned accounts were redirected to another account, specifically that of the "Sorting Manager," in order to proceed with the distribution of the clients of the terminated collaborators.

No document has been produced to ascertain that clients received an automatic response message informing them of the deactivation of the email addresses (of the terminated collaborators).

In fact, the document "Aruba Guide – Managing Domain Mailboxes" (attached n. 16 to the note of 16/06/2022) contains only instructions on how to set up forwarding and redirecting email functions, but is not in itself suitable to demonstrate that the procedures were actually followed by the Agency.

Nor has any documentation been produced to verify that the "Sorting Manager" could not access the content of the messages, except with prior authorization from the IT Manager and/or the owner.

Rather, from the documentation produced and the statements made by the party, under their own responsibility, it appears that the emails in transit on the accounts of former collaborators were read by the "Sorting Manager," also to implement the stated purpose of proceeding with the distribution of clients among the collaborators (in this regard, reference is made to attachment 7 to the note of 06/04/2022, in which the IT Manager writes to the Sorting Manager informing him that "pending a reorganization of the client portfolio, in order to manage any emails in entry, for the mailboxes of the users of ... the automatic forwarding to your corporate email has been set up." Of the same tenor is the email dated 29/04/2020, attached as document 4 to the report of 09/06/2021, sent by the distribution manager to another employee of the Agency, which states "I am forwarding to you below, received at the address of XX."

It should be noted that even the mere reading of the so-called "external data" of electronic communications (that is, the senders and/or recipients of the emails and their subjects) constitutes a processing of personal data pursuant to Article 4, paragraph 2, of the Regulation.

It has been established that access to the correspondence in transit on the aforementioned accounts was allowed to the IT Manager. Therefore, it must be considered confirmed the observation already notified to the party, regarding the activity of automatic redirection of messages in transit on the accounts of terminated collaborators to another corporate account, which lasted for a period of 120 days.

This activity has resulted in the knowledge of the content of the messages received by unauthorized third parties and has lasted for a period that must be considered excessive and not commensurate with actual organizational needs, considering that the Agency has stated that it has distributed the client portfolio, initially assigned to the two reporters, within a time frame of 30 days, also informing clients about the names of the new contacts (note of 06/04/2022) and that "according to IVASS directives, within 7 days from the termination of the employment relationship with a collaborator, the name of the new agent must be communicated to the client" (statement made during the hearing of 08/02/2023).

The conduct of the Agency, as described, is in contrast with the principles and provisions regarding the protection of personal data. In this regard, it is noted that in the provision containing the "Guidelines for electronic mail and the internet" adopted on 01/03/2007 (available on the Authority's website www.gpdp.it, web doc no. 1387522), any processing of data related to communications sent and received by the worker at the corporate email account must be carried out in compliance with the principles of necessity, fairness, relevance, and non-excessiveness, as well as with a level of protection capable of preventing unjustified interference with the fundamental rights of workers, third-party senders, and/or recipients of the same communications.

These principles are fully applicable also with reference to professional and collaborative relationships that, although not characterized by a dependency relationship, still grant the data controller a broad organizational power, both internal and external, as is the case here.

It follows that the employer, after the termination of the employment or collaboration relationship as in the case at hand, must proceed to remove the individualized corporate email account, after deactivating it and simultaneously adopting automatic systems aimed at informing third parties and providing them with alternative addresses, thereby avoiding the viewing of incoming communications on the individualized account assigned to the interested party.

This assumption has been reiterated several times by the Guarantor in its provisions, most recently in provision no. 68 of 09/03/2023 (see also provision no. 551 of 27/11/2014, web doc no. 3718714, provision no. 136 of 05/03/2015, web doc no. 3985524).

Therefore, while ensuring the continuity of business activity, also considering the regulations regarding insurance, it is observed that the conduct carried out by the Agency, related to the failure to deactivate accounts and the activity of redirecting emails, is not compliant with the principles of lawfulness and limitation of retention, as provided for by Article 5, paragraph 1, letters a) and e) of the Regulation.

3.2 Violation of Article 5, paragraph 1, letters c) and e) of the Regulation.

It is noted that, during the proceedings, the Agency did not provide any clarification regarding the further profiles of unlawfulness that emerged during the investigation, particularly concerning the retention of internet access logs and email during the collaboration relationship, carried out without time limits, and any control that may have been conducted.

The only statement on this specific point was made by the party during the hearing, where it was stated that "the Agency does not have its own backup."

This statement, unsupported by any documentation, does not clarify the critical aspects related to the retention of email logs as described in attachment 7 to the appointment as a social security consultant, containing "Behavioral rules regarding the use of corporate IT resources," which was delivered and signed by both reporters on 28/05/2018 (attachment 20 to the note of 16/06/2022).

Therefore, in the absence of other elements that may refute the notified observations, the unlawfulness of the Agency's conduct, consisting of the systematic retention without time limits of internet access logs and email during the collaboration relationship, must be confirmed and is, therefore, contrary to the principles of retention limitation and minimization set forth in Articles 5, paragraph 1, letters c) and e) of the Regulation.

3.3 Violation of Articles 5, paragraph 1, letters c) and e),

****6. Article of the Regulation.****

Similarly, it must be considered confirmed, in the absence of any argument from the party, the contested observation against the Agency concerning the indefinite retention of the content of correspondence that passes through the email accounts assigned to its collaborators, following the termination of the collaboration relationship.

In this regard, the aforementioned document titled "Rules of Conduct Regarding the Use of Company IT Resources" expressly provides for the indefinite retention of the content of email ("and other IT resources") assigned to former collaborators, leaving the Agency the discretion to use this information

“for reasons related to the conduct of business activities.”

In this context, reference is made to the Authority's pronouncements on this specific aspect, which clarify, first and foremost, that “the legitimate need to ensure the retention of documentation necessary for the ordinary conduct and continuity of business activities, also in relation to relationships maintained with private and public entities, as well as based on specific provisions of the legal framework, is primarily ensured by the establishment of document management systems through which – by adopting appropriate organizational and technological measures – to identify the documents that during the course of work activities must be archived in ways suitable to guarantee the characteristics of authenticity, integrity, reliability, readability, and retrievability prescribed by the applicable sector regulations. Email systems, by their very nature, do not allow for the assurance of such characteristics” (see provision no. 53 of 01/02/2018, web doc no. 8159221 and provision no. 214 of 29/10/2020, web doc 9518890).

The aim of establishing tools for the ordinary and efficient management of company document flows, therefore, can well be pursued, in accordance with current regulations, with less invasive tools for the right to privacy of the interested parties, compared to the above-described activity of access by the Agency to the content of communications received on the accounts assigned to collaborators, which is therefore deemed unnecessary and disproportionate in relation to the purpose (see provision no. 53 of 01/02/2018, web doc 8159221).

Therefore, the conduct of the Agency, consisting of the indefinite retention of the content of the correspondence that passed through the individualized email accounts of the two whistleblowers, as well as their retrievability for mere purposes of continuity of business activities, as established during the investigation, is unlawful, as it was carried out in the absence of a lawful basis pursuant to Article 6 of the Regulation, and contrary to the principles of minimization and limitation of retention set forth in Article 5, paragraph 1, letters c) and e) of the Regulation.

****4. Conclusions: declaration of unlawfulness of the processing. Corrective measures pursuant to Article 58, paragraph 2, of the Regulation.****

For the reasons stated above, the Authority believes that the statements made by the data controller during the investigation do not allow for overcoming the observations notified by the Office with the initiation of the proceedings concerning Articles 5, paragraph 1, letters a), c) and e), and 6 of the Regulation, which are therefore unsuitable to allow for the archiving of the present proceedings, nor is there, with respect to these aspects, any of the cases provided for by Article 11 of the Garante Regulation no. 1/2019.

Given the corrective powers conferred by Article 58, paragraph 2, of the Regulation, in light of the circumstances of the specific case:

- the Agency is ordered to align its corporate regulation on the use of IT tools with the provisions on personal data protection, concerning the further processing of data related to the email accounts assigned to its collaborators, both during the employment relationship and after its termination;
- a monetary administrative sanction is imposed pursuant to Article 83 of the Regulation.

****5. Adoption of the injunction order for the application of the monetary administrative sanction and accessory sanctions (Articles 58, paragraph 2, letter i), and 83 of the Regulation; Article 166, paragraph 7, of the Code).****

As a result of the proceedings, it is found that Maviglia Assicurazioni Snc has violated Articles 5, paragraph 1, letters a), c) and e), and 6 of the Regulation. For the violation of the aforementioned provisions, the application of the monetary administrative sanction provided for by Article 83, paragraph 5, letter a), of the Regulation is foreseen, through the adoption of an injunction order (Article 18, Law 24.11.1981, no. 689).

It is deemed necessary to apply paragraph 3 of Article 83 of the Regulation, which provides that “If, in relation to the same processing or related treatments, a data controller [...] violates, with intent or negligence, various provisions of this regulation, the total amount of the monetary administrative sanction does not exceed the amount specified for the most serious violation,” the total amount of the sanction is calculated so as not to exceed the maximum penalty provided for by the same Article 83,

paragraph 5.

With reference to the elements listed in Article 83, paragraph 2, of the Regulation for the application of the monetary administrative sanction and its quantification, taking into account that the

****Sanction must "in any case [be] effective, proportional and dissuasive" (art. 83, par. 1 of the Regulation), it is represented that, in the specific case, the following circumstances have been considered:****

- a) in relation to the nature, severity, and duration of the violation, the nature of the violation concerning the general principles of processing has been deemed relevant;
- b) with reference to the intentional or negligent character of the violation and the degree of responsibility of the data controller, the conduct of the Agency has been taken into account, as well as its degree of responsibility, which does not appear to have complied, even after the opening of the procedure, with the regulations regarding data protection concerning multiple provisions;
- c) in favor of the party, account has been taken of the absence of specific previous offenses.

It is also believed that the economic conditions of the offender, determined based on the tax declaration for the year 2021, are relevant in this case, considering the aforementioned principles of effectiveness, proportionality, and dissuasiveness to which the Authority must adhere in determining the amount of the sanction (art. 83, par. 1, of the Regulation). Lastly, account is taken of the amount of sanctions imposed in similar cases.

In light of the above elements and the evaluations made, it is deemed appropriate, in this specific case, to apply an administrative sanction against Maviglia Assicurazioni Snc di Gherardo Maviglia & c. in the amount of €5,000.00 (five thousand).

In this context, it is also considered, in light of the type of violations identified that concern the general principles of processing, that, pursuant to art. 166, par. 7, of the Code and art. 16, par. 1, of the Garante Regulation no. 1/2019, the publication of this provision on the Garante's website should proceed.

It is also believed that the conditions set forth in art. 17 of Regulation no. 1/2019 are met.

****ALL OF THE ABOVE CONSIDERED, THE Garante****

notes the illegality of the processing of data relating to the two whistleblowers, carried out by Maviglia Assicurazioni Snc di Gherardo Maviglia & c., represented by the legal representative pro tempore, with registered office in Rome, Via della Pineta di Ostia n. 10, P.I. 11507251004, pursuant to art. 143 of the Code, for the violation of arts. 5, par. 1, lett. a), c), e) and 6 of the Regulation;

****ORDERS****

pursuant to art. 58, par. 2, lett. i) of the Regulation, Maviglia Assicurazioni Snc di Gherardo Maviglia & c. to pay the sum of €5,000.00 (five thousand) as an administrative pecuniary sanction for the violations indicated in this provision;

pursuant to art. 58, par. 2, lett. d) of the Regulation, to align the company regulations on the use of IT tools with the data protection regulations as outlined in the reasoning within 90 days from the date of notification of this provision;

****ORDERS****

therefore the same Company to pay the aforementioned sum of €5,000.00 (five thousand), according to the methods indicated in the annex, within 30 days from the notification of this provision, under penalty of the adoption of the consequent executive acts pursuant to art. 27 of Law no. 689/1981.

It is reminded that the offender retains the option to settle the dispute by paying – always according to the methods indicated in the annex – an amount equal to half of the imposed sanction, within the term provided for the filing of the appeal as indicated below (art. 10, par. 3, of Legislative Decree no. 150 of 1.9.2011) (art. 166, par. 8, of the Code);

****DISPOSES****

the publication of this provision on the Garante's website pursuant to art. 166, par. 7, of the Code and

art. 16, par. 1, of the Garante Regulation no. 1/2019, and believes that the conditions set forth in art. 17 of Regulation no. 1/2019 are met.

Requests the company to communicate what initiatives have been undertaken in order to implement the provisions of this provision and to provide adequately documented feedback pursuant to art. 157 of the Code, within 90 days from the date of notification of this provision; any failure to respond may result in the application of the administrative sanction provided for in art. 83, par. 5, lett. e) of the Regulation.

Pursuant to art. 78 of the Regulation, as well as arts. 152 of the Code and 10 of Legislative Decree no. 150/2011, an appeal against this provision may be filed with the ordinary judicial authority, with a petition submitted to the ordinary court of the place indicated in the same art. 10, within thirty days from the date of communication of the provision itself, or sixty days if the appellant resides abroad.

Rome, June 22, 2023

THE PRESIDENT

Stanzione

THE REPORTER

Scorza

THE DEPUTY SECRETARY GENERAL

Filippi